

QUESTION 1

Which of the following countermeasure can specifically protect against both the MAC Flood and MAC Spoofing attacks?

- A. Configure Port Security on the switch
- B. Configure Port Recon on the switch
- C. Configure Switch Mapping
- D. Configure Multiple Recognition on the switch

Correct Answer: A

QUESTION 2

Jimmy, an attacker, knows that he can take advantage of poorly designed input validation routines to create or alter SQL commands to gain access to private data or execute commands in the database.

What technique does Jimmy use to compromise a database?

- A. Jimmy can submit user input that executes an operating system command to compromise a target system
- B. Jimmy can gain control of system to flood the target system with requests, preventing legitimate users from gaining access
- C. Jimmy can utilize an incorrect configuration that leads to access with higher-than expected privilege of the database
- D. Jimmy can utilize this particular database threat that is an SQL injection technique to penetrate a target system

Correct Answer: D

QUESTION 3

This IDS defeating technique works by splitting a datagram (or packet) into multiple fragments and the IDS will not spot the true nature of the fully assembled datagram. The datagram is not reassembled until it reaches its final destination. It would be a processor-intensive task for IDS to reassemble all fragments itself, and on a busy system the packet will slip through the IDS onto the network. What is this technique called?

- A. IP Routing or Packet Dropping
- B. IDS Spoofing or Session Assembly
- C. IP Fragmentation or Session Splicing
- D. IP Splicing or Packet Reassembly

Correct Answer: C

QUESTION 4

This type of Port Scanning technique splits TCP header into several packets so that the packet filters are not able to detect what the packets intends to do.

- A. UDP Scanning
- B. IP Fragment Scanning
- C. Inverse TCP flag scanning
- D. ACK flag scanning

Correct Answer: B

QUESTION 5

Joel and her team have been going through tons of garbage, recycled paper, and other rubbish in order to find some information about the target they are attempting to penetrate. How would you call this type of activity?

- A. Dumpster Diving
- B. Scanning

- C. CI Gathering
- D. Garbage Scooping

Correct Answer: A

QUESTION 6

Anonymizer sites access the Internet on your behalf, protecting your personal information from disclosure. An anonymizer protects all of your computer's identifying information while it surfs for you, enabling you to remain at least one step removed from the sites you visit.

You can visit Web sites without allowing anyone to gather information on sites visited by you. Services that provide anonymity disable pop-up windows and cookies, and conceal visitor's IP address.

These services typically use a proxy server to process each HTTP request. When the user requests a Web page by clicking a hyperlink or typing a URL into their browser, the service retrieves and displays the information using its own server. The remote server (where the requested Web page resides) receives information on the anonymous Web surfing service in place of your information.

In which situations would you want to use anonymizer? (Select 3 answers)

- A. Increase your Web browsing bandwidth speed by using Anonymizer
- B. To protect your privacy and Identity on the Internet
- C. To bypass blocking applications that would prevent access to Web sites or parts of sites that you want to visit.
- D. Post negative entries in blogs without revealing your IP identity

Correct Answer: BCD

QUESTION 7

Jack Hacker wants to break into Brown Co.'s computers and obtain their secret double fudge cookie recipe. Jack calls Jane, an accountant at Brown Co., pretending to be an administrator from Brown Co. Jack tells Jane that there has been a problem with some accounts and asks her to verify her password with him "just to double check our records." Jane does not suspect anything amiss, and parts with her password. Jack can now access Brown Co.'s computers with a valid user name and password, to steal the cookie recipe. What kind of attack is being illustrated here?

- A. Reverse Psychology
- B. Reverse Engineering
- C. Social Engineering
- D. Spoofing Identity
- E. Faking Identity

Correct Answer: C

QUESTION 8

How do you defend against ARP Spoofing? Select three.

- A. Use ARPWALL system and block ARP spoofing attacks
- B. Tune IDS Sensors to look for large amount of ARP traffic on local subnets
- C. Use private VLANS
- D. Place static ARP entries on servers, workstation and routers

Correct Answer: ACD

QUESTION 9

TCP SYN Flood attack uses the three-way handshake mechanism.

1. An attacker at system A sends a SYN packet to victim at system B.
2. System B sends a SYN/ACK packet to victim A.
3. As a normal three-way handshake mechanism system A should send an ACK packet to system B, however, system A does not send an ACK packet to system B. In this case client B is waiting for an ACK

packet from client A.

This status of client B is called _____

- A. "half-closed"
- B. "half open"
- C. "full-open"
- D. "xmas-open"

Correct Answer: B

QUESTION 10

Lori is a Certified Ethical Hacker as well as a Certified Hacking Forensics Investigator working as an IT security consultant. Lori has been hired on by Kiley Innovators, a large marketing firm that recently underwent a string of thefts and corporate espionage incidents. Lori is told that a rival marketing company came out with an exact duplicate product right before Kiley Innovators was about to release it. The executive team believes that an employee is leaking information to the rival company. Lori questions all employees, reviews server logs, and firewall logs; after which she finds nothing. Lori is then given permission to search through the corporate email system. She searches by email being sent to and sent from the rival marketing company.

She finds one employee that appears to be sending very large email to this other marketing company, even though they should have no reason to be communicating with them. Lori tracks down the actual emails sent and upon opening them, only finds picture files attached to them. These files seem perfectly harmless, usually containing some kind of joke. Lori decides to use some special software to further examine the pictures and finds that each one had hidden text that was stored in each picture.

What technique was used by the Kiley Innovators employee to send information to the rival marketing company?

- A. The Kiley Innovators employee used cryptography to hide the information in the emails sent
- B. The method used by the employee to hide the information was logical watermarking
- C. The employee used steganography to hide information in the picture attachments
- D. By using the pictures to hide information, the employee utilized picture fuzzing

Correct Answer: C

QUESTION 11

How do you defend against Privilege Escalation?

- A. Use encryption to protect sensitive data
- B. Restrict the interactive logon privileges
- C. Run services as unprivileged accounts
- D. Allow security settings of IE to zero or Low
- E. Run users and applications on the least privileges

Correct Answer: ABCE

QUESTION 12

What does ICMP (type 11, code 0) denote?

- A. Source Quench
- B. Destination Unreachable
- C. Time Exceeded
- D. Unknown Type

Correct Answer: C

QUESTION 13

More sophisticated IDSs look for common shellcode signatures. But even these systems can be bypassed, by using polymorphic shellcode. This is a technique common among virus writers ?it basically hides the true nature of the shellcode in different disguises.

How does a polymorphic shellcode work?

- A. They encrypt the shellcode by XORing values over the shellcode, using loader code to decrypt the shellcode, and then executing the decrypted shellcode
- B. They convert the shellcode into Unicode, using loader to convert back to machine code then executing them
- C. They reverse the working instructions into opposite order by masking the IDS signatures
- D. They compress shellcode into normal instructions, uncompress the shellcode using loader code and then executing the shellcode

Correct Answer: A

QUESTION 14

SYN Flood is a DOS attack in which an attacker deliberately violates the three-way handshake and opens a large number of half-open TCP connections. The signature of attack for SYN Flood contains:

- A. The source and destination address having the same value
- B. A large number of SYN packets appearing on a network without the corresponding reply packets
- C. The source and destination port numbers having the same value
- D. A large number of SYN packets appearing on a network with the corresponding reply packets

Correct Answer: B

QUESTION 15

Which of the following type of scanning utilizes automated process of proactively identifying vulnerabilities of the computing systems present on a network?

- A. Port Scanning
- B. Single Scanning
- C. External Scanning
- D. Vulnerability Scanning

Correct Answer: D

QUESTION 16

What are the limitations of Vulnerability scanners? (Select 2 answers)

- A. There are often better at detecting well-known vulnerabilities than more esoteric ones
- B. The scanning speed of their scanners are extremely high
- C. It is impossible for any, one scanning product to incorporate all known vulnerabilities in a timely manner
- D. The more vulnerabilities detected, the more tests required
- E. They are highly expensive and require per host scan license

Correct Answer: AC

QUESTION 17

Stephanie works as senior security analyst for a manufacturing company in Detroit. Stephanie manages network security throughout the organization. Her colleague Jason told her in confidence that he was able to see confidential corporate information posted on the external website

<http://www.jeansclothesman.com>. He tries random URLs on the company's website and finds confidential information leaked over the web. Jason says this happened about a month ago. Stephanie visits the said URLs, but she finds nothing. She is very concerned about this, since someone should be held accountable if there was sensitive information posted on the website. Where can Stephanie go to see

past versions and pages of a website?

- A. She should go to the web page Samspace.org to see web pages that might no longer be on the website
- B. If Stephanie navigates to Search.com; she will see old versions of the company website
- C. Stephanie can go to Archive.org to see past versions of the company website
- D. AddressPast.com would have any web pages that are no longer hosted on the company's website

Correct Answer: C

QUESTION 18

Dan is conducting penetration testing and has found a vulnerability in a Web Application which gave him the sessionID token via a cross site scripting vulnerability. Dan wants to replay this token. However, the session ID manager (on the server) checks the originating IP address as well. Dan decides to spoof his IP address in order to replay the sessionID. Why do you think Dan might not be able to get an interactive session?

- A. Dan cannot spoof his IP address over TCP network
- B. The scenario is incorrect as Dan can spoof his IP and get responses
- C. The server will send replies back to the spoofed IP address
- D. Dan can establish an interactive session only if he uses a NAT

Correct Answer: C

QUESTION 19

Jason works in the sales and marketing department for a very large advertising agency located in Atlanta. Jason is working on a very important marketing campaign for his company's largest client. Before the project could be completed and implemented, a competing advertising company comes out with the exact same marketing materials and advertising, thus rendering all the work done for Jason's client unusable. Jason is questioned about this and says he has no idea how all the material ended up in the hands of a competitor.

Without any proof, Jason's company cannot do anything except move on. After working on another high profile client for about a month, all the marketing and sales material again ends up in the hands of another competitor and is released to the public before Jason's company can finish the project. Once again, Jason says that he had nothing to do with it and does not know how this could have happened. Jason is given leave with pay until they can figure out what is going on.

Jason's supervisor decides to go through his email and finds a number of emails that were sent to the competitors that ended up with the marketing material. The only items in the emails were attached jpg files, but nothing else. Jason's supervisor opens the picture files, but cannot find anything out of the ordinary with them.

What technique has Jason most likely used?

- A. Stealth Rootkit Technique
- B. ADS Streams Technique
- C. Snow Hiding Technique
- D. Image Steganography Technique

Correct Answer: D

QUESTION 20

How does traceroute map the route a packet travels from point A to point B?

- A. Uses a TCP timestamp packet that will elicit a time exceeded in transit message
- B. Manipulates the value of the time to live (TTL) within packet to elicit a time exceeded in transit message
- C. Uses a protocol that will be rejected by gateways on its way to the destination

D. Manipulates the flags within packets to force gateways into generating error messages

Correct Answer: B

QUESTION 21

How do you defend against DHCP Starvation attack?

- A. Enable ARP-Block on the switch
- B. Enable DHCP snooping on the switch
- C. Configure DHCP-BLOCK to 1 on the switch
- D. Install DHCP filters on the switch to block this attack

Correct Answer: B

QUESTION 22

Neil is a network administrator working in Istanbul. Neil wants to setup a protocol analyzer on his network that

will receive a copy of every packet that passes through the main office switch. What type of port will Neil need

to setup in order to accomplish this?

- A. Neil will have to configure a Bridged port that will copy all packets to the protocol analyzer.
- B. Neil will need to setup SPAN port that will copy all network traffic to the protocol analyzer.
- C. He will have to setup an Ether channel port to get a copy of all network traffic to the analyzer.
- D. He should setup a MODS port which will copy all network traffic.

Correct Answer: B

QUESTION 23

How many bits encryption does SHA-1 use?

- A. 64 bits
- B. 128 bits
- C. 256 bits
- D. 160 bits

Correct Answer: D

QUESTION 24

In Trojan terminology, what is required to create the executable file chess.exe as shown below?



- A. Mixer
- B. Converter
- C. Wrapper
- D. Zipper

Correct Answer: C

QUESTION 25

This attack uses social engineering techniques to trick users into accessing a fake Web site and divulging personal information. Attackers send a legitimate-looking e-mail asking users to update their information on the

company's Web site, but the URLs in the e-mail actually point to a false Web site.

- A. Wiresharp attack
- B. Switch and bait attack
- C. Phishing attack
- D. Man-in-the-Middle attack

Correct Answer: C

QUESTION 26

Which of the following statements would NOT be a proper definition for a Trojan Horse?

- A. An authorized program that has been designed to capture keyboard keystroke while the user is unaware of such activity being performed
- B. An unauthorized program contained within a legitimate program. This unauthorized program performs functions unknown (and probably unwanted) by the user
- C. A legitimate program that has been altered by the placement of unauthorized code within it; this code performs functions unknown (and probably unwanted) by the user
- D. Any program that appears to perform a desirable and necessary function but that (because of unauthorized code within it that is unknown to the user) performs functions unknown (and definitely unwanted) by the user

Correct Answer: A

QUESTION 27

What is the correct command to run Netcat on a server using port 56 that spawns command shell when connected?

- A. nc -port 56 -s cmd.exe
- B. nc -p 56 -p -e shell.exe
- C. nc -r 56 -c cmd.exe
- D. nc -L 56 -t -e cmd.exe

Correct Answer: D

QUESTION 28

SNMP is a connectionless protocol that uses UDP instead of TCP packets (True or False)

- A. true
- B. false

Correct Answer: A

QUESTION 29

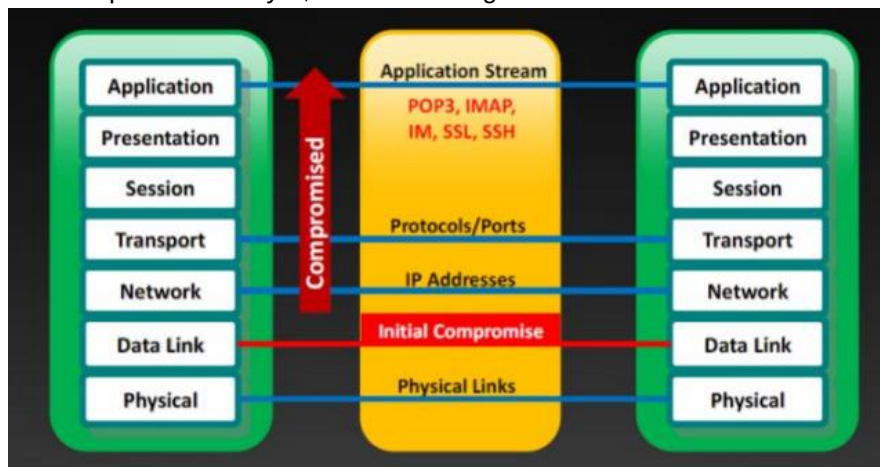
TCP/IP Session Hijacking is carried out in which OSI layer?

- A. Datalink layer
- B. Transport layer
- C. Network layer
- D. Physical layer

Correct Answer: B

QUESTION 30

In which part of OSI layer, ARP Poisoning occurs?



- A. Transport Layer
- B. Datalink Layer
- C. Physical Layer
- D. Application layer

Correct Answer: B

QUESTION 31

In the context of Trojans, what is the definition of a Wrapper?

- A. An encryption tool to protect the Trojan

- B. A tool used to bind the Trojan with a legitimate file
- C. A tool used to calculate bandwidth and CPU cycles wasted by the Trojan
- D. A tool used to encapsulate packets within a new header and footer

Correct Answer: B

QUESTION 32

Your computer is infected by E-mail tracking and spying Trojan. This Trojan infects the computer with a single file - emos.sys

Which step would you perform to detect this type of Trojan?

- A. Scan for suspicious startup programs using msconfig
- B. Scan for suspicious network activities using Wireshark
- C. Scan for suspicious device drivers in c:\windows\system32\drivers
- D. Scan for suspicious open ports using netstat

Correct Answer: C

QUESTION 33

Which type of hacker represents the highest risk to your network?

- A. black hat hackers
- B. grey hat hackers
- C. disgruntled employees
- D. script kiddies

Correct Answer: C

QUESTION 34

Shayla is an IT security consultant, specializing in social engineering and external penetration tests. Shayla has been hired on by Treks Avionics, a subcontractor for the Department of Defense. Shayla has been given authority to perform any and all tests necessary to audit the company's network security. No employees for the company, other than the IT director, know about Shayla's work she will be doing. Shayla's first step is to obtain a list of employees through company website contact pages. Then she befriends a female employee of the company through an online chat website. After meeting with the female employee numerous times, Shayla is able to gain her trust and they become friends. One day, Shayla steals the employee's access badge and uses it to gain unauthorized access to the Treks Avionics offices.

What type of insider threat would Shayla be considered?

- A. She would be considered an Insider Affiliate
- B. Because she does not have any legal access herself, Shayla would be considered an Outside Affiliate
- C. Shayla is an Insider Associate since she has befriended an actual employee
- D. Since Shayla obtained access with a legitimate company badge; she would be considered a Pure Insider

Correct Answer: A

QUESTION 35

What port number is used by Kerberos protocol?

- A. 88
- B. 44
- C. 487
- D. 41 9

Correct Answer: A

QUESTION 36

What does FIN in TCP flag define?

- A. Used to abort a TCP connection abruptly
- B. Used to close a TCP connection
- C. Used to acknowledge receipt of a previous packet or transmission
- D. Used to indicate the beginning of a TCP connection

Correct Answer: B

QUESTION 37

Annie has just succeeded in stealing a secure cookie via a XSS attack. She is able to replay the cookie even while the session is invalid on the server. Why do you think this is possible?

- A. It works because encryption is performed at the application layer (single encryption key)
- B. The scenario is invalid as a secure cookie cannot be replayed
- C. It works because encryption is performed at the network layer (layer 1 encryption)
- D. Any cookie can be replayed irrespective of the session status

Correct Answer: A

QUESTION 38

This attack technique is used when a Web application is vulnerable to an SQL Injection but the results of the Injection are not visible to the attacker.

- A. Unique SQL Injection
- B. Blind SQL Injection
- C. Generic SQL Injection
- D. Double SQL Injection

Correct Answer: B

QUESTION 39

You are the Security Administrator of Xtrinity, Inc. You write security policies and conduct assessments to protect the company's network. During one of your periodic checks to see how well policy is being observed by the employees, you discover an employee has attached cell phone 3G modem to his telephone line and workstation. He has used this cell phone 3G modem to dial in to his workstation, thereby bypassing your firewall. A security breach has occurred as a direct result of this activity. The employee explains that he used the modem because he had to download software for a department project. How would you resolve this situation?

- A. Reconfigure the firewall
- B. Enforce the corporate security policy
- C. Install a network-based IDS
- D. Conduct a needs analysis

Correct Answer: B

QUESTION 40

In what stage of Virus life does a stealth virus gets activated with the user performing certain actions such as running an infected program?

- A. Design
- B. Elimination
- C. Incorporation
- D. Replication
- E. Launch

F. Detection

Correct Answer: E

QUESTION 41

What is a sniffing performed on a switched network called?

- A. Spoofed sniffing
- B. Passive sniffing
- C. Direct sniffing
- D. Active sniffing

Correct Answer: D

QUESTION 42

Which Steganography technique uses Whitespace to hide secret messages?

- A. snow
- B. beetle
- C. magnet
- D. cat

Correct Answer: A

QUESTION 43

David is a security administrator working in Boston. David has been asked by the office's manager to block all POP3 traffic at the firewall because he believes employees are spending too much time reading personal email.

How can David block POP3 at the firewall?

- A. David can block port 1 25 at the firewall.
- B. David can block all EHLO requests that originate from inside the office.
- C. David can stop POP3 traffic by blocking all HELO requests that originate from inside the office.
- D. David can block port 1 1 0 to block all POP3 traffic.

Correct Answer: D

QUESTION 44

You want to capture Facebook website traffic in Wireshark. What display filter should you use that shows all TCP packets that contain the word 'facebook'?

- A. display==facebook
- B. traffic.content==facebook
- C. tcp contains facebook
- D. list.display.facebook

Correct Answer: C

QUESTION 45

How would you describe an attack where an attacker attempts to deliver the payload over multiple packets over long periods of time with the purpose of defeating simple pattern matching in IDS systems without session reconstruction? A characteristic of this attack would be a continuous stream of small packets.

- A. Session Hijacking
- B. Session Stealing
- C. Session Splicing
- D. Session Fragmentation

Correct Answer: C

QUESTION 46

Jake works as a system administrator at Acme Corp. Jason, an accountant of the firm befriends him at the canteen and tags along with him on the pretext of appraising him about potential tax benefits. Jason waits for Jake to swipe his access card and follows him through the open door into the secure systems area. How would you describe Jason's behavior within a security context?

- A. Smooth Talking
- B. Swipe Gating
- C. Tailgating
- D. Trailing

Correct Answer: C

QUESTION 47

While performing a ping sweep of a local subnet you receive an ICMP reply of Code 3/Type 1 3 for all the pings you have sent out. What is the most likely cause of this?

- A. The firewall is dropping the packets
- B. An in-line IDS is dropping the packets
- C. A router is blocking ICMP
- D. The host does not respond to ICMP packets

Correct Answer: C

QUESTION 48

Maintaining a secure Web server requires constant effort, resources, and vigilance from an organization. Securely administering a Web server on a daily basis is an essential aspect of Web server security. Maintaining the security of a Web server will usually involve the following steps:

1. Configuring, protecting, and analyzing log files
2. Backing up critical information frequently
3. Maintaining a protected authoritative copy of the organization's Web content
4. Establishing and following procedures for recovering from compromise
5. Testing and applying patches in a timely manner
6. Testing security periodically.

In which step would you engage a forensic investigator?

- A. 1
- B. 2
- C. 3
- D. 4
- E. 5
- F. 6

Correct Answer: D

QUESTION 49

In Buffer Overflow exploit, which of the following registers gets overwritten with return address of the exploit code?

- A. EEP
- B. ESP
- C. EAP
- D. EIP

Correct Answer: D

QUESTION 50

Web servers often contain directories that do not need to be indexed. You create a text file with search engine indexing restrictions and place it on the root directory of the Web Server.

User-agent: *

Disallow: /images/

Disallow: /banners/

Disallow: /Forms/

Disallow: /Dictionary/

Disallow: /_borders/

Disallow: /_fpclass/

Disallow: /_overlay/

Disallow: /_private/

Disallow: /_themes/

What is the name of this file?

A. robots.txt

B. search.txt

C. blocklist.txt

D. spf.txt

Correct Answer: A

QUESTION 51

An attacker has successfully compromised a remote computer. Which of the following comes as one of the last steps that should be taken to ensure that the compromise cannot be traced back to the source of the problem?

A. Install patches

B. Setup a backdoor

C. Install a zombie for DDOS

D. Cover your tracks

Correct Answer: D

QUESTION 52

What is War Dialing?

A. War dialing involves the use of a program in conjunction with a modem to penetrate the modem/PBX-based systems

B. War dialing is a vulnerability scanning technique that penetrates Firewalls

C. It is a social engineering technique that uses Phone calls to trick victims

D. Involves IDS Scanning Fragments to bypass Internet filters and stateful Firewalls

Correct Answer: A

QUESTION 53

Steven the hacker realizes the network administrator of Acme Corporation is using syskey in Windows 2008 Server to protect his resources in the organization. Syskey independently encrypts the hashes so that physical access to the server, tapes, or ERDs is only first step to cracking the passwords. Steven must break through the encryption used by syskey before he can attempt to use brute force dictionary attacks on the hashes.

Steven runs a program called "SysCracker" targeting the Windows 2008 Server machine in attempting to crack the hash used by Syskey. He needs to configure the encryption level before he can launch the attack. How many bits does Syskey use for encryption?

- A. 40-bit encryption
- B. 128-bit encryption
- C. 256-bit encryption
- D. 64-bit encryption

Correct Answer: B

QUESTION 54

Bob waits near a secured door, holding a box. He waits until an employee walks up to the secured door and uses the special card in order to access the restricted area of the target company. Just as the employee opens the door, Bob walks up to the employee (still holding the box) and asks the employee to hold the door open so that he can enter. What is the best way to undermine the social engineering activity of tailgating?

- A. Issue special cards to access secure doors at the company and provide a one-time only brief description of use of the special card
- B. Educate and enforce physical security policies of the company to all the employees on a regular basis
- C. Setup a mock video camera next to the special card reader adjacent to the secure door
- D. Post a sign that states, "no tailgating" next to the special card reader adjacent to the secure door

Correct Answer: B

QUESTION 55

Ursula is a college student at a University in Amsterdam. Ursula originally went to college to study engineering but later changed to marine biology after spending a month at sea with her friends. These friends frequently go out to sea to follow and harass fishing fleets that illegally fish in foreign waters. Ursula eventually wants to put companies practicing illegal fishing out of business. Ursula decides to hack into the parent company's computers and destroy critical data knowing fully well that, if caught, she probably would be sent to jail for a very long time. What would Ursula be considered?

- A. Ursula would be considered a gray hat since she is performing an act against illegal activities.
- B. She would be considered a suicide hacker.
- C. She would be called a cracker.
- D. Ursula would be considered a black hat.

Correct Answer: B

QUESTION 56

Attacking well-known system defaults is one of the most common hacker attacks. Most software is shipped with a default configuration that makes it easy to install and setup the application. You should change the default settings to secure the system.

Which of the following is NOT an example of default installation?

- A. Many systems come with default user accounts with well-known passwords that administrators forget to change
- B. Often, the default location of installation files can be exploited which allows a hacker to retrieve a file from the system
- C. Many software packages come with "samples" that can be exploited, such as the sample programs on IIS web services
- D. Enabling firewall and anti-virus software on the local system

Correct Answer: D

QUESTION 57

In the context of password security: a simple dictionary attack involves loading a dictionary file (a text file full of dictionary words) into a cracking application such as L0phtCrack or John the Ripper, and running it

against user accounts located by the application. The larger the word and word fragment selection, the more effective the dictionary attack is. The brute force method is the most inclusive - though slow. Usually, it tries every possible letter and number combination in its automated exploration. If you would use both brute force and dictionary combined together to have variations of words, what would you call such an attack?

- A. Full Blown Attack
- B. Thorough Attack
- C. Hybrid Attack
- D. BruteDict Attack

Correct Answer: C

QUESTION 58

You receive an e-mail with the following text message.

"Microsoft and HP today warned all customers that a new, highly dangerous virus has been discovered which will erase all your files at midnight. If there's a file called hidserv.exe on your computer, you have been infected and your computer is now running a hidden server that allows hackers to access your computer. Delete the file immediately. Please also pass this message to all your friends and colleagues as soon as possible."

You launch your antivirus software and scan the suspicious looking file hidserv.exe located in c:\windows directory and the AV comes out clean meaning the file is not infected. You view the file signature and confirm that it is a legitimate Windows system file "Human Interface Device Service".

What category of virus is this?

- A. Virus hoax
- B. Spooky Virus
- C. Stealth Virus
- D. Polymorphic Virus

Correct Answer: A

QUESTION 59

One of the effective DoS/DDoS countermeasures is 'Throttling'. Which statement correctly defines this term?

- A. Set up routers that access a server with logic to adjust incoming traffic to levels that will be safe for the server to process
- B. Providers can increase the bandwidth on critical connections to prevent them from going down in the event of an attack
- C. Replicating servers that can provide additional failsafe protection
- D. Load balance each server in a multiple-server architecture

Correct Answer: A

QUESTION 60

Which of the following tool would be considered as Signature Integrity Verifier (SIV)?

- A. Nmap
- B. SNORT
- C. VirusSCAN
- D. Tripwire

Correct Answer: D

QUESTION 61

Bob has set up three web servers on Windows Server 2008 IIS 7.0. Bob has followed all the

recommendations for securing the operating system and IIS. These servers are going to run numerous e-commerce websites that are projected to bring in thousands of dollars a day. Bob is still concerned about the security of these servers because of the potential for financial loss. Bob has asked his company's firewall administrator to set the firewall to inspect all incoming traffic on ports 80 and 443 to ensure that no malicious data is getting into the network.

Why will this not be possible?

- A. Firewalls cannot inspect traffic coming through port 443
- B. Firewalls can only inspect outbound traffic
- C. Firewalls cannot inspect traffic at all, they can only block or allow certain ports
- D. Firewalls cannot inspect traffic coming through port 80

Correct Answer: C

QUESTION 62

Which of the following statement correctly defines ICMP Flood Attack? (Select 2 answers)

- A. Bogus ECHO reply packets are flooded on the network spoofing the IP and MAC address
- B. The ICMP packets signal the victim system to reply and the combination of traffic saturates the bandwidth of the victim's network
- C. ECHO packets are flooded on the network saturating the bandwidth of the subnet causing denial of service
- D. A DDoS ICMP flood attack occurs when the zombies send large volumes of ICMP_ECHO_REPLY packets to the victim system.

Correct Answer: BD

QUESTION 63

Which type of scan does NOT open a full TCP connection?

- A. Stealth Scan
- B. XMAS Scan
- C. Null Scan
- D. FIN Scan

Correct Answer: A

QUESTION 64

What sequence of packets is sent during the initial TCP three-way handshake?

- A. SYN, SYN-ACK, ACK
- B. SYN, URG, ACK
- C. SYN, ACK, SYN-ACK
- D. FIN, FIN-ACK, ACK

Correct Answer: A

QUESTION 65

Steve scans the network for SNMP enabled devices. Which port number Steve should scan?

- A. 1 50
- B. 1 61
- C. 1 69
- D. 69

Correct Answer: B

QUESTION 66

You are footprinting an organization and gathering competitive intelligence. You visit the company's

website for contact information and telephone numbers but do not find them listed there. You know they had the entire staff directory listed on their website 12 months ago but now it is not there. Is there any way you can retrieve information from a website that is outdated?

- A. Visit Google's search engine and view the cached copy
- B. Crawl the entire website and store them into your computer
- C. Visit Archive.org web site to retrieve the Internet archive of the company's website
- D. Visit the company's partners and customers website for this information

Correct Answer: C

QUESTION 67

You are the CIO for Avantes Finance International, a global finance company based in Geneva. You are responsible for network functions and logical security throughout the entire corporation. Your company has over 250 servers running Windows Server, 5000 workstations running Windows Vista, and 200 mobile users working from laptops on Windows 7.

Last week, 10 of your company's laptops were stolen from salesmen while at a conference in Amsterdam. These laptops contained proprietary company information. While doing damage assessment on the possible public relations nightmare this may become, a news story leaks about the stolen laptops and also that sensitive information from those computers was posted to a blog online.

What built-in Windows feature could you have implemented to protect the sensitive information on these laptops?

- A. You should have used 3DES which is built into Windows
- B. If you would have implemented Pretty Good Privacy (PGP) which is built into Windows, the sensitive information on the laptops would not have leaked out
- C. You should have utilized the built-in feature of Distributed File System (DFS) to protect the sensitive information on the laptops
- D. You could have implemented Encrypted File System (EFS) to encrypt the sensitive files on the laptops

Correct Answer: D

QUESTION 68

Which of the following is NOT part of CEH Scanning Methodology?

- A. Check for Live systems
- B. Check for Open Ports
- C. Banner Grabbing
- D. Prepare Proxies
- E. Social Engineering attacks
- F. Scan for Vulnerabilities
- G. Draw Network Diagrams

Correct Answer: E

QUESTION 69

Lee is using Wireshark to log traffic on his network. He notices a number of packets being directed to an internal IP from an outside IP where the packets are ICMP and their size is around 65,536 bytes. What is Lee seeing here?

- A. Lee is seeing activity indicative of a Smurf attack.
- B. Most likely, the ICMP packets are being sent in this manner to attempt IP spoofing.
- C. Lee is seeing a Ping of death attack.

D. This is not unusual traffic, ICMP packets can be of any size.

Correct Answer: C

QUESTION 70

This method is used to determine the Operating system and version running on a remote target system. What is it called?

- A. Service Degradation
- B. OS Fingerprinting
- C. Manual Target System
- D. Identification Scanning

Correct Answer: B

QUESTION 71

John the hacker is sniffing the network to inject ARP packets. He injects broadcast frames onto the wire to conduct MiTM attack. What is the destination MAC address of a broadcast frame?

- A. 0xFFFFFFFFFFFF
- B. 0xDDDDDDDDDDDD
- C. 0xAAAAAAAAAAAA
- D. 0BBBBBBBBBBBBBB

Correct Answer: A

QUESTION 72

You are gathering competitive intelligence on an organization. You notice that they have jobs listed on a few Internet job-hunting sites. There are two jobs for network and system administrators. How can this help you in foot printing the organization?

- A. To learn about the IP range used by the target network
- B. To identify the number of employees working for the company
- C. To test the limits of the corporate security policy enforced in the company
- D. To learn about the operating systems, services and applications used on the network

Correct Answer: D

QUESTION 73

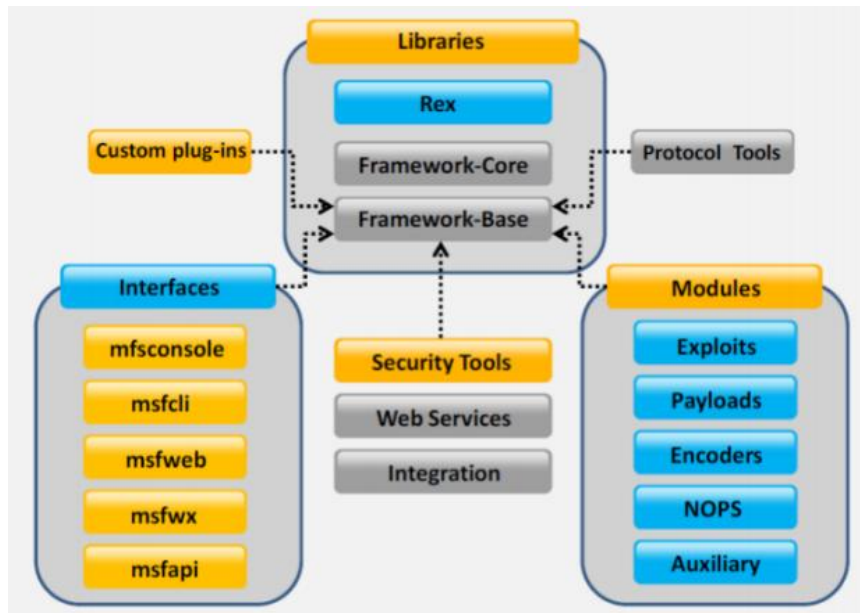
TCP packets transmitted in either direction after the initial three-way handshake will have which of the following bit set?

- A. SYN flag
- B. ACK flag
- C. FIN flag
- D. XMAS flag

Correct Answer: B

QUESTION 74

What framework architecture is shown in this exhibit?



- A. Core Impact
- B. Metasploit
- C. Immunity Canvas
- D. Nessus

Correct Answer: B

QUESTION 75

Which of the following steganography utilities exploits the nature of white space and allows the user to conceal information in these white spaces?

- A. Image Hide
- B. Snow
- C. Gif-It-Up
- D. NiceText

Correct Answer: B

QUESTION 76

While testing web applications, you attempt to insert the following test script into the search area on the company's web site:

```
<script>alert('Testing Testing Testing')</script>
```

Later, when you press the search button, a pop up box appears on your screen with the text "Testing Testing Testing". What vulnerability is detected in the web application here?

- A. Cross Site Scripting
- B. Password attacks
- C. A Buffer Overflow
- D. A hybrid attack

Correct Answer: A

QUESTION 77

What techniques would you use to evade IDS during a Port Scan? (Select 4 answers)

- A. Use fragmented IP packets
- B. Spoof your IP address when launching attacks and sniff responses from the server

- C. Overload the IDS with Junk traffic to mask your scan
- D. Use source routing (if possible)
- E. Connect to proxy servers or compromised Trojaned machines to launch attacks

Correct Answer: ABDE

QUESTION 78

Bob was frustrated with his competitor, Brownies Inc., and decided to launch an attack that would result in serious financial losses. He planned the attack carefully and carried out the attack at the appropriate moment.

Meanwhile, Trent, an administrator at Brownies Inc., realized that their main financial transaction server had been attacked. As a result of the attack, the server crashed and Trent needed to reboot the system, as no one was able to access the resources of the company. This process involves human interaction to fix it.

What kind of Denial of Service attack was best illustrated in the scenario above?

- A. Simple DDoS attack
- B. DoS attacks which involves flooding a network or system
- C. DoS attacks which involves crashing a network or system
- D. DoS attacks which is done accidentally or deliberately

Correct Answer: C

QUESTION 79

Johnny is a member of the hacking group Orpheus1 . He is currently working on breaking into the Department of Defense's front end Exchange Server. He was able to get into the server, located in a DMZ, by using an unused service account that had a very weak password that he was able to guess. Johnny wants to crack the administrator password, but does not have a lot of time to crack it. He wants to use a tool that already has the LM hashes computed for all possible permutations of the administrator password.

What tool would be best used to accomplish this?

- A. SMBCrack
- B. SmurfCrack
- C. PSCrack
- D. RainbowTables

Correct Answer: D

QUESTION 80

The FIN flag is set and sent from host A to host B when host A has no more data to transmit (Closing a TCP connection). This flag releases the connection resources. However, host A can continue to receive data as long as the SYN sequence numbers of transmitted packets from host B are lower than the packet segment containing the set FIN flag.

- A. false
- B. true

Correct Answer: B

QUESTION 81

Leesa is the senior security analyst for a publicly traded company. The IT department recently rolled out an intranet for company use only with information ranging from training, to holiday schedules, to human resources data. Leesa wants to make sure the site is not accessible from outside and she also wants to ensure the site is Sarbanes-Oxley (SOX) compliant. Leesa goes to a public library as she wants to do some Google searching to verify whether the company's intranet is accessible from outside and has been

indexed by Google. Leesa wants to search for a website title of "intranet" with part of the URL containing the word "intranet" and the words "human resources" somewhere in the webpage.

What Google search will accomplish this?

- A. related:intranet allinurl:intranet:"human resources"
- B. cache:"human resources" inurl:intranet(SharePoint)
- C. intitle:intranet inurl:intranet+intext:"human resources"
- D. site:"human resources"+intext:intranet intitle:intranet

Correct Answer: C

QUESTION 82

Bob has been hired to do a web application security test. Bob notices that the site is dynamic and must make use of a back end database. Bob wants to see if SQL Injection would be possible. What is the first character that Bob should use to attempt breaking valid SQL request?

- A. Semi Column
- B. Double Quote
- C. Single Quote
- D. Exclamation Mark

Correct Answer: C

QUESTION 83

Hampton is the senior security analyst for the city of Columbus in Ohio. His primary responsibility is to ensure that all physical and logical aspects of the city's computer network are secure from all angles. Bill is an IT technician that works with Hampton in the same IT department. Bill's primary responsibility is to keep PC's and servers up to date and to keep track of all the agency laptops that the company owns and lends out to its employees. After Bill setup a wireless network for the agency, Hampton made sure that everything was secure.

He instituted encryption, rotating keys, turned off SSID broadcasting, and enabled MAC filtering.

According to agency policy, only company laptops are allowed to use the wireless network, so Hampton entered all the MAC addresses for those laptops into the wireless security utility so that only those laptops should be able to access the wireless network.

Hampton does not keep track of all the laptops, but he is pretty certain that the agency only purchases Dell laptops. Hampton is curious about this because he notices Bill working on a Toshiba laptop one day and saw that he was on the Internet. Instead of jumping to conclusions, Hampton decides to talk to Bill's boss and see if they had purchased a Toshiba laptop instead of the usual Dell. Bill's boss said no, so now Hampton is very curious to see how Bill is accessing the Internet. Hampton does site surveys every couple of days, and has yet to see any outside wireless network signals inside the company's building.

How was Bill able to get Internet access without using an agency laptop?

- A. Bill spoofed the MAC address of Dell laptop
- B. Bill connected to a Rogue access point
- C. Toshiba and Dell laptops share the same hardware address
- D. Bill brute forced the Mac address ACLs

Correct Answer: A

QUESTION 84

LAN Manager Passwords are concatenated to 14 bytes, and split in half. The two halves are hashed individually. If the password is 7 characters or less, then the second half of the hash is always:

- A. 0xAAD3B435B51 404EE
- B. 0xAAD3B435B51 404AA
- C. 0xAAD3B435B51 404BB

D. 0xAAD3B435B51 404CC

Correct Answer: A

QUESTION 85

Jess the hacker runs L0phtCrack's built-in sniffer utility that grabs SMB password hashes and stores them for offline cracking. Once cracked, these passwords can provide easy access to whatever network resources the user account has access to. But Jess is not picking up hashes from the network. Why?

- A. The network protocol is configured to use SMB Signing
- B. The physical network wire is on fibre optic cable
- C. The network protocol is configured to use IPSEC
- D. L0phtCrack SMB sniffing only works through Switches and not Hubs

Correct Answer: A

QUESTION 86

Harold works for Jacobson Unlimited in the IT department as the security manager. Harold has created a security policy requiring all employees to use complex 14 character passwords. Unfortunately, the members of management do not want to have to use such long complicated passwords so they tell Harold's boss this new password policy should not apply to them. To comply with the management's wishes, the IT department creates another Windows domain and moves all the management users to that domain. This new domain has a password policy only requiring 8 characters.

Harold is concerned about having to accommodate the managers, but cannot do anything about it. Harold is also concerned about using LanManager security on his network instead of NTLM or NTLMv2, but the many legacy applications on the network prevent using the more secure NTLM and NTLMv2. Harold pulls the SAM files from the DC's on the original domain and the new domain using Pwdump6.

Harold uses the password cracking software John the Ripper to crack users' passwords to make sure they are strong enough. Harold expects that the users' passwords in the original domain will take much longer to crack than the management's passwords in the new domain. After running the software, Harold discovers that the 14 character passwords only took a short time longer to crack than the 8 character passwords.

Why did the 14 character passwords not take much longer to crack than the 8 character passwords?

- A. Harold should have used Dumpsec instead of Pwdump6
- B. Harold's dictionary file was not large enough
- C. Harold should use LC4 instead of John the Ripper
- D. LanManager hashes are broken up into two 7 character fields

Correct Answer: D

QUESTION 87

Which of the following Trojans would be considered 'Botnet Command Control Center'?

- A. YouKill DOOM
- B. Damen Rock
- C. Poison Ivy
- D. Matten Kit

Correct Answer: C

QUESTION 88

John is using a special tool on his Linux platform that has a database containing signatures to be able to detect hundreds of vulnerabilities in UNIX, Windows, and commonly used web CGI/ASPX scripts.

Moreover, the database detects DDoS zombies and Trojans as well. What would be the name of this tool?

- A. hping3
- B. nessus
- C. nmap
- D. make

Correct Answer: B

QUESTION 89

Fred is scanning his network to ensure it is as secure as possible. Fred sends a TCP probe packet to a host with a FIN flag and he receives a RST/ACK response. What does this mean?

- A. This response means the port he is scanning is open.
- B. The RST/ACK response means the port Fred is scanning is disabled.
- C. This means the port he is scanning is half open.
- D. This means that the port he is scanning on the host is closed.

Correct Answer: D

QUESTION 90

_____ is a type of symmetric-key encryption algorithm that transforms a fixed-length block of plaintext (unencrypted text) data into a block of ciphertext (encrypted text) data of the same length.

- A. Stream Cipher
- B. Block Cipher
- C. Bit Cipher
- D. Hash Cipher

Correct Answer: B

QUESTION 91

Your company has blocked all the ports via external firewall and only allows port 80/443 to connect to the Internet. You want to use FTP to connect to some remote server on the Internet.

How would you accomplish this?

- A. Use HTTP Tunneling
- B. Use Proxy Chaining
- C. Use TOR Network
- D. Use Reverse Chaining

Correct Answer: A

QUESTION 92

You have successfully gained access to a victim's computer using Windows 2003 Server SMB Vulnerability.

Which command will you run to disable auditing from the cmd?

- A. stoplog stoplog ?
- B. EnterPol /nolog
- C. EventViewer o service
- D. auditpol.exe /disable

Correct Answer: D

QUESTION 93

How do you defend against MAC attacks on a switch?

- A. Disable SPAN port on the switch
- B. Enable SNMP Trap on the switch
- C. Configure IP security on the switch

D. Enable Port Security on the switch

Correct Answer: D

QUESTION 94

In which location, SAM hash passwords are stored in Windows 7?

A. c:\windows\system32\config\SAM

B. c:\winnt\system32\machine\SAM

C. c:\windows\etc\drivers\SAM

D. c:\windows\config\etc\SAM

Correct Answer: A

QUESTION 95

File extensions provide information regarding the underlying server technology. Attackers can use this information to search vulnerabilities and launch attacks. How would you disable file extensions in Apache servers?

A. Use disable-eXchange

B. Use mod_negotiation

C. Use Stop_Files

D. Use Lib_exchanges

Correct Answer: B

QUESTION 96

Bob has a good understanding of cryptography, having worked with it for many years. Cryptography is used to secure data from specific threats, but it does not secure the application from coding errors. It can provide data privacy; integrity and enable strong authentication but it cannot mitigate programming errors. What is a good example of a programming error that Bob can use to explain to the management how encryption will not address all their security concerns?

A. Bob can explain that using a weak key management technique is a form of programming error

B. Bob can explain that using passwords to derive cryptographic keys is a form of a programming error

C. Bob can explain that a buffer overflow is an example of programming error and it is a common mistake associated with poor programming technique

D. Bob can explain that a random number generator can be used to derive cryptographic keys but it uses a weak seed value and this is a form of a programming error

Correct Answer: A

QUESTION 97

One of the most common and the best way of cracking RSA encryption is to begin to derive the two prime numbers, which are used in the RSA PKI mathematical process. If the two numbers p and q are discovered through a _____ process, then the private key can be derived.

A. Factorization

B. Prime Detection

C. Hashing

D. Brute-forcing

Correct Answer: A

QUESTION 98

Data is sent over the network as clear text (unencrypted) when Basic Authentication is configured on Web Servers.

A. true

B. false

Correct Answer: A

QUESTION 99

NetBIOS over TCP/IP allows files and/or printers to be shared over the network. You are trying to intercept the traffic from a victim machine to a corporate network printer. You are attempting to hijack the printer network connection from your laptop by sniffing the wire. Which port does SMB over TCP/IP use?

A. 443

B. 139

C. 179

D. 445

Correct Answer: D

QUESTION 100

What type of encryption does WPA2 use?

A. DES 64 bit

B. AES-CCMP 128 bit

C. MD5 48 bit

D. SHA 160 bit

Correct Answer: B

QUESTION 101

Attackers send an ACK probe packet with random sequence number, no response means port is filtered (Stateful firewall is present) and RST response means the port is not filtered. What type of Port Scanning is this?

A. RST flag scanning

B. FIN flag scanning

C. SYN flag scanning

D. ACK flag scanning

Correct Answer: D

QUESTION 102

What is the command used to create a binary log file using tcpdump?

A. tcpdump -w ./log

B. tcpdump -r log

C. tcpdump -vde logtcpdump -vde ? log

D. tcpdump -l /var/log/

Correct Answer: A

QUESTION 103

Which port, when configured on a switch receives a copy of every packet that passes through it?

A. R-DUPE Port

B. MIRROR port

C. SPAN port

D. PORTMON

Correct Answer: C

QUESTION 104

What is the IV key size used in WPA2?

- A. 32
- B. 24
- C. 16
- D. 48
- E. 128

Correct Answer: D

QUESTION 105

What is the default Password Hash Algorithm used by NTLMv2?

- A. MD4
- B. DES
- C. SHA-1
- D. MD5

Correct Answer: D

QUESTION 106

Gerald, the Systems Administrator for Hyped Enterprises, has just discovered that his network has been breached by an outside attacker. After performing routine maintenance on his servers, he discovers numerous remote tools were installed that no one claims to have knowledge of in his department. Gerald logs onto the management console for his IDS and discovers an unknown IP address that scanned his network constantly for a week and was able to access his network through a high-level port that was not closed. Gerald traces the IP address he found in the IDS log to a proxy server in Brazil. Gerald calls the company that owns the proxy server and after searching through their logs, they trace the source to another proxy server in Switzerland. Gerald calls the company in Switzerland that owns the proxy server and after scanning through the logs again, they trace the source back to a proxy server in China. What proxy tool has Gerald's attacker used to cover their tracks?

- A. ISA proxy
- B. IAS proxy
- C. TOR proxy
- D. Cheops proxy

Correct Answer: C

QUESTION 107

Frederickson Security Consultants is currently conducting a security audit on the networks of Hawthorn Enterprises, a contractor for the Department of Defense. Since Hawthorn Enterprises conducts business daily with the federal government, they must abide by very stringent security policies. Frederickson is testing all of Hawthorn's physical and logical security measures including biometrics, passwords, and permissions. The federal government requires that all users must utilize random, non-dictionary passwords that must take at least 30 days to crack. Frederickson has confirmed that all Hawthorn employees use a random password generator for their network passwords. The Frederickson consultants have saved off numerous SAM files from Hawthorn's servers using Pwdump6 and are going to try and crack the network passwords. What method of attack is best suited to crack these passwords in the shortest amount of time?

- A. Brute force attack
- B. Birthday attack
- C. Dictionary attack
- D. Brute service attack

Correct Answer: A

QUESTION 108

You want to know whether a packet filter is in front of 192.168.1.10. Pings to 192.168.1.10 don't get answered. A basic nmap scan of 192.168.1.10 seems to hang without returning any information. What should you do next?

- A. Run NULL TCP hping2 against 192.168.1.10
- B. Run nmap XMAS scan against 192.168.1.10
- C. The firewall is blocking all the scans to 192.168.1.10
- D. Use NetScan Tools Pro to conduct the scan

Correct Answer: A

QUESTION 109

A digital signature is simply a message that is encrypted with the public key instead of the private key.

- A. true
- B. false

Correct Answer: B

QUESTION 110

Blane is a network security analyst for his company. From an outside IP, Blane performs an XMAS scan using Nmap. Almost every port scanned does not illicit a response. What can he infer from this kind of response?

- A. These ports are open because they do not illicit a response.
- B. He can tell that these ports are in stealth mode.
- C. If a port does not respond to an XMAS scan using NMAP, that port is closed.
- D. The scan was not performed correctly using NMAP since all ports, no matter what their state, will illicit some sort of response from an XMAS scan.

Correct Answer: A

QUESTION 111

A simple compiler technique used by programmers is to add a terminator 'canary word' containing four letters NULL (0x00), CR (0x0d), LF (0x0a) and EOF (0xff) so that most string operations are terminated. If the canary word has been altered when the function returns, and the program responds by emitting an intruder alert into syslog, and then halts what does it indicate?

- A. A buffer overflow attack has been attempted
- B. A buffer overflow attack has already occurred
- C. A firewall has been breached and this is logged
- D. An intrusion detection system has been triggered
- E. The system has crashed

Correct Answer: A

QUESTION 112

Neil is closely monitoring his firewall rules and logs on a regular basis. Some of the users have complained to Neil that there are a few employees who are visiting offensive web site during work hours, without any consideration for others. Neil knows that he has an up-to-date content filtering system and such access should not be authorized. What type of technique might be used by these offenders to access the Internet without restriction?

- A. They are using UDP that is always authorized at the firewall
- B. They are using HTTP tunneling software that allows them to communicate with protocols in a way it was not intended
- C. They have been able to compromise the firewall, modify the rules, and give themselves proper access

D. They are using an older version of Internet Explorer that allow them to bypass the proxy server

Correct Answer: B

QUESTION 113

Bob is going to perform an active session hijack against Brownies Inc. He has found a target that allows session oriented connections (Telnet) and performs the sequence prediction on the target operating system. He manages to find an active session due to the high level of traffic on the network. What is Bob supposed to do next?

- A. Take over the session
- B. Reverse sequence prediction
- C. Guess the sequence numbers
- D. Take one of the parties offline

Correct Answer: C

QUESTION 114

"Testing the network using the same methodologies and tools employed by attackers" Identify the correct terminology that defines the above statement.

- A. Vulnerability Scanning
- B. Penetration Testing
- C. Security Policy Implementation
- D. Designing Network Security

Correct Answer: B

QUESTION 115

Nathan is testing some of his network devices. Nathan is using Macof to try and flood the ARP cache of these switches. If these switches' ARP cache is successfully flooded, what will be the result?

- A. The switches will drop into hub mode if the ARP cache is successfully flooded.
- B. If the ARP cache is flooded, the switches will drop into pix mode making it less susceptible to attacks.
- C. Depending on the switch manufacturer, the device will either delete every entry in its ARP cache or reroute packets to the nearest switch.
- D. The switches will route all traffic to the broadcast address created collisions.

Correct Answer: A

QUESTION 116

This TCP flag instructs the sending system to transmit all buffered data immediately.

- A. SYN
- B. RST
- C. PSH
- D. URG
- E. FIN

Correct Answer: C

QUESTION 117

Study the snort rule given below and interpret the rule.

alert tcp any any --> 1 92.1 68.1 .0/24 1 1 1 (content:"|00 01 86 a5|"; msg: "mountd access");

A. An alert is generated when a TCP packet is generated from any IP on the 1 92.1 68.1 .0 subnet and destined to any IP on port 1 1 1

B. An alert is generated when any packet other than a TCP packet is seen on the network and destined for the 192.168.1.0 subnet

- C. An alert is generated when a TCP packet is originated from port 111 of any IP address to the 192.168.1.0 subnet
- D. An alert is generated when a TCP packet originating from any IP address is seen on the network and destined for any IP address on the 192.168.1.0 subnet on port 111

Correct Answer: D

QUESTION 118

What port number is used by LDAP protocol?

- A. 110
- B. 389
- C. 464
- D. 445

Correct Answer: B

QUESTION 119

Fred is the network administrator for his company. Fred is testing an internal switch. From an external IP address, Fred wants to try and trick this switch into thinking it already has established a session with his computer. How can Fred accomplish this?

- A. Fred can accomplish this by sending an IP packet with the RST/SIN bit and the source address of his computer.
- B. He can send an IP packet with the SYN bit and the source address of his computer.
- C. Fred can send an IP packet with the ACK bit set to zero and the source address of the switch.
- D. Fred can send an IP packet to the switch with the ACK bit and the source address of his machine.

Correct Answer: D

QUESTION 120

Within the context of Computer Security, which of the following statements describes Social Engineering best?

- A. Social Engineering is the act of publicly disclosing information
- B. Social Engineering is the means put in place by human resource to perform time accounting
- C. Social Engineering is the act of getting needed information from a person rather than breaking into a system
- D. Social Engineering is a training program within sociology studies

Correct Answer: C

QUESTION 121

When a normal TCP connection starts, a destination host receives a SYN (synchronize/start) packet from a source host and sends back a SYN/ACK (synchronize acknowledge). The destination host must then hear an ACK (acknowledge) of the SYN/ACK before the connection is established. This is referred to as the "TCP three way handshake."

While waiting for the ACK to the SYN ACK, a connection queue of finite size on the destination host keeps track of connections waiting to be completed. This queue typically empties quickly since the ACK is expected to arrive a few milliseconds after the SYN ACK. How would an attacker exploit this design by launching TCP SYN attack?

- A. Attacker generates TCP SYN packets with random destination addresses towards a victim host
- B. Attacker floods TCP SYN packets with random source addresses towards a victim host
- C. Attacker generates TCP ACK packets with random source addresses towards a victim host
- D. Attacker generates TCP RST packets with random source addresses towards a victim host

Correct Answer: B

QUESTION 122

Yancey is a network security administrator for a large electric company. This company provides power for over 1 00, 000 people in Las Vegas. Yancey has worked for his company for over 15 years and has become very successful. One day, Yancey comes in to work and finds out that the company will be downsizing and he will be out of a job in two weeks. Yancey is very angry and decides to place logic bombs, viruses, Trojans, and backdoors all over the network to take down the company once he has left. Yancey does not care if his actions land him in jail for 30 or more years, he just wants the company to pay for what they are doing to him. What would Yancey be considered?

- A. Yancey would be considered a Suicide Hacker
- B. Since he does not care about going to jail, he would be considered a Black Hat
- C. Because Yancey works for the company currently; he would be a White Hat
- D. Yancey is a Hactivist Hacker since he is standing up to a company that is downsizing

Correct Answer: A

QUESTION 123

Every company needs a formal written document which spells out to employees precisely what they are allowed to use the company's systems for, what is prohibited, and what will happen to them if they break the rules. Two printed copies of the policy should be given to every employee as soon as possible after they join the organization. The employee should be asked to sign one copy, which should be safely filed by the company. No one should be allowed to use the company's computer systems until they have signed the policy in acceptance of its terms. What is this document called?

- A. Information Audit Policy (IAP)
- B. Information Security Policy (ISP)
- C. Penetration Testing Policy (PTP)
- D. Company Compliance Policy (CCP)

Correct Answer: B

QUESTION 124

Which type of sniffing technique is generally referred as MiTM attack?

- A. Password Sniffing
- B. ARP Poisoning
- C. Mac Flooding
- D. DHCP Sniffing

Correct Answer: B

QUESTION 125

How does a denial-of-service attack work?

- A. A hacker prevents a legitimate user (or group of users) from accessing a service
- B. A hacker uses every character, word, or letter he or she can think of to defeat authentication
- C. A hacker tries to decipher a password by using a system, which subsequently crashes the network
- D. A hacker attempts to imitate a legitimate user by confusing a computer or even another person

Correct Answer: A

QUESTION 126

This is an attack that takes advantage of a web site vulnerability in which the site displays content that includes un-sanitized user-provided data.

```
<a href="http://foobar.com/index.html?id=%3Cscript%20src=%22http://baddomain.com/badscript.js%22%3E%3C/script%3E">See foobar</a>
```

What is this attack?

- A. Cross-site-scripting attack
- B. SQL Injection
- C. URL Traversal attack
- D. Buffer Overflow attack

Correct Answer: A

QUESTION 127

Which of the following encryption is NOT based on block cipher?

- A. DES
- B. Blowfish
- C. AES (Rijndael)
- D. RC4

Correct Answer: D

QUESTION 128

In which step Steganography fits in CEH System Hacking Cycle (SHC)

- A. Step 2: Crack the password
- B. Step 1 : Enumerate users
- C. Step 3: Escalate privileges
- D. Step 4: Execute applications
- E. Step 5: Hide files
- F. Step 6: Cover your tracks

Correct Answer: E

QUESTION 129

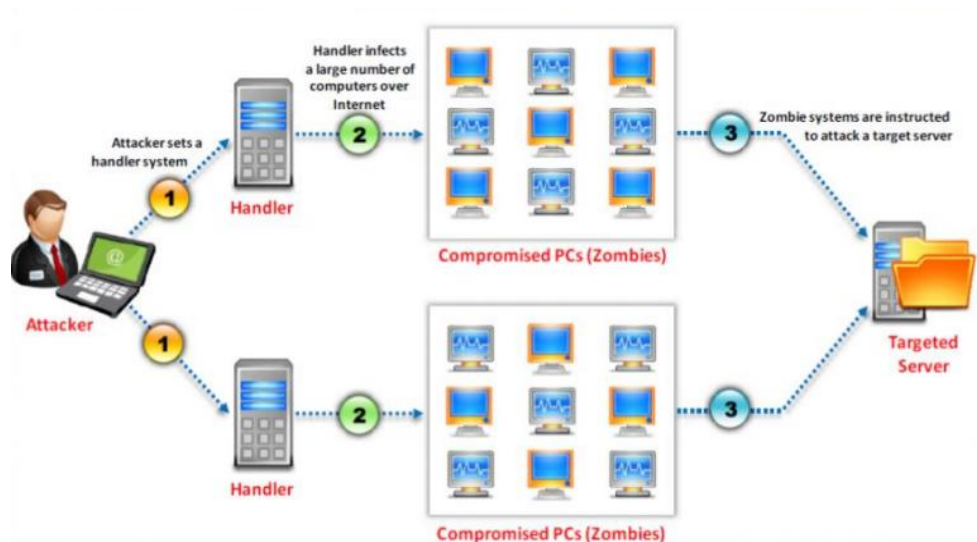
Which definition below best describes a covert channel?

- A. A server program using a port that is not well known
- B. Making use of a protocol in a way it was not intended to be used
- C. It is the multiplexing taking place on a communication link
- D. It is one of the weak channels used by WEP that makes it insecure

Correct Answer: B

QUESTION 130

What type of attack is shown here?



- A. Bandwidth exhaust Attack
- B. Denial of Service Attack
- C. Cluster Service Attack
- D. Distributed Denial of Service Attack

Correct Answer: D

QUESTION 131

To see how some of the hosts on your network react, Winston sends out SYN packets to an IP range. A number of IPs respond with a SYN/ACK response. Before the connection is established he sends RST packets to those hosts to stop the session. Winston has done this to see how his intrusion detection system will log the traffic. What type of scan is Winston attempting here?

- A. Winston is attempting to find live hosts on your company's network by using an XMAS scan.
- B. He is utilizing a SYN scan to find live hosts that are listening on your network.
- C. This type of scan he is using is called a NULL scan.
- D. He is using a half-open scan to find live hosts on your network.

Correct Answer: D

QUESTION 132

John runs a Web server, IDS and firewall on his network. Recently his Web server has been under constant hacking attacks. He looks up the IDS log files and sees no intrusion attempts but the Web server constantly locks up and needs rebooting due to various brute force and buffer overflow attacks but still the IDS alerts no intrusion whatsoever. John becomes suspicious and views the Firewall logs and he notices huge SSL connections constantly hitting his Web server. Hackers have been using the encrypted HTTPS protocol to send exploits to the Web server and that was the reason the IDS did not detect the intrusions. How would John protect his network from these types of attacks?

- A. Install a proxy server and terminate SSL at the proxy
- B. Enable the IDS to filter encrypted HTTPS traffic
- C. Install a hardware SSL "accelerator" and terminate SSL at this layer
- D. Enable the Firewall to filter encrypted HTTPS traffic

Correct Answer: AC

QUESTION 133

Jane wishes to forward X-Windows traffic to a remote host as well as POP3 traffic. She is worried that

adversaries might be monitoring the communication link and could inspect captured traffic. She would like to tunnel the information to the remote end but does not have VPN capabilities to do so. Which of the following tools can she use to protect the link?

- A. MD5
- B. PGP
- C. RSA
- D. SSH

Correct Answer: D

QUESTION 134

NTP allows you to set the clocks on your systems very accurately, to within 1 00ms and sometimes-even 1 0ms. Knowing the exact time is extremely important for enterprise security. Various security protocols depend on an accurate source of time information in order to prevent "playback" attacks. These protocols tag their communications with the current time, to prevent attackers from replaying the same communications, e.g., a login/password interaction or even an entire communication, at a later date. One can circumvent this tagging, if the clock can be set back to the time the communication was recorded. An attacker attempts to try corrupting the clocks on devices on your network. You run Wireshark to detect the NTP traffic to see if there are any irregularities on the network. What port number you should enable in Wireshark display filter to view NTP packets?

- A. TCP Port 1 24
- B. UDP Port 1 25
- C. UDP Port 1 23
- D. TCP Port 1 26

Correct Answer: C

QUESTION 135

What is the length of the MD5 hash?

- A. 32 character
- B. 64 byte
- C. 48 char
- D. 1 28 kb

Correct Answer: A

QUESTION 136

Which type of password cracking technique works like dictionary attack but adds some numbers and symbols to the words from the dictionary and tries to crack the password?

- A. Dictionary attack
- B. Brute forcing attack
- C. Hybrid attack
- D. Syllable attack
- E. Rule-based attack

Correct Answer: C

QUESTION 137

What do you call a pre-computed hash?

- A. Sun tables
- B. Apple tables
- C. Rainbow tables

D. Moon tables

Correct Answer: C

QUESTION 138

Why attackers use proxy servers?

- A. To ensure the exploits used in the attacks always flip reverse vectors
- B. Faster bandwidth performance and increase in attack speed
- C. Interrupt the remote victim's network traffic and reroute the packets to attackers machine
- D. To hide the source IP address so that an attacker can hack without any legal corollary

Correct Answer: D

QUESTION 139

The SNMP Read-Only Community String is like a password. The string is sent along with each SNMP GetRequest and allows (or denies) access to a device. Most network vendors ship their equipment with a default password of "public". This is the so-called "default public community string". How would you keep intruders from getting sensitive information regarding the network devices using SNMP? (Select 2 answers)

- A. Enable SNMPv3 which encrypts username/password authentication
- B. Use your company name as the public community string replacing the default 'public'
- C. Enable IP filtering to limit access to SNMP device
- D. The default configuration provided by device vendors is highly secure and you don't need to change anything

Correct Answer: AC

QUESTION 140

You are writing security policy that hardens and prevents Footprinting attempt by Hackers. Which of the following countermeasures will NOT be effective against this attack?

- A. Configure routers to restrict the responses to Footprinting requests
- B. Configure Web Servers to avoid information leakage and disable unwanted protocols
- C. Lock the ports with suitable Firewall configuration
- D. Use an IDS that can be configured to refuse suspicious traffic and pick up Footprinting patterns
- E. Evaluate the information before publishing it on the Website/Intranet
- F. Monitor every employee computer with Spy cameras, keyloggers and spy on them
- G. Perform Footprinting techniques and remove any sensitive information found on DMZ sites
- H. Prevent search engines from caching a Webpage and use anonymous registration services
- I. Disable directory and use split-DNS

Correct Answer: F

QUESTION 141

WWW wanderers or spiders are programs that traverse many pages in the World Wide Web by recursively retrieving linked pages. Search engines like Google, frequently spider web pages for indexing. How will you stop web spiders from crawling certain directories on your website?

- A. Place robots.txt file in the root of your website with listing of directories that you don't want to be crawled
- B. Place authentication on root directories that will prevent crawling from these spiders
- C. Enable SSL on the restricted directories which will block these spiders from crawling
- D. Place "HTTP:NO CRAWL" on the html pages that you don't want the crawlers to index

Correct Answer: A

QUESTION 142

Hayden is the network security administrator for her company, a large finance firm based in Miami. Hayden just returned from a security conference in Las Vegas where they talked about all kinds of old and new security threats; many of which she did not know of. Hayden is worried about the current security state of her company's network so she decides to start scanning the network from an external IP address. To see how some of the hosts on her network react, she sends out SYN packets to an IP range. A number of IPs responds with a SYN/ ACK response. Before the connection is established she sends RST packets to those hosts to stop the session.

She does this to see how her intrusion detection system will log the traffic. What type of scan is Hayden attempting here?

- A. Hayden is attempting to find live hosts on her company's network by using an XMAS scan
- B. She is utilizing a SYN scan to find live hosts that are listening on her network
- C. The type of scan, she is using is called a NULL scan
- D. Hayden is using a half-open scan to find live hosts on her network

Correct Answer: D

QUESTION 143

If an attacker's computer sends an IPID of 24333 to a zombie (Idle Scanning) computer on a closed port, what will be the response?

- A. The zombie computer will respond with an IPID of 24334.
- B. The zombie computer will respond with an IPID of 24333.
- C. The zombie computer will not send a response.
- D. The zombie computer will respond with an IPID of 24335.

Correct Answer: A

QUESTION 144

Jacob is looking through a traffic log that was captured using Wireshark. Jacob has come across what appears to be SYN requests to an internal computer from a spoofed IP address. What is Jacob seeing here?

- A. Jacob is seeing a Smurf attack.
- B. Jacob is seeing a SYN flood.
- C. He is seeing a SYN/ACK attack.
- D. He has found evidence of an ACK flood.

Correct Answer: B

QUESTION 145

Perimeter testing means determining exactly what your firewall blocks and what it allows. To conduct a good test, you can spoof source IP addresses and source ports. Which of the following command results in packets that will appear to originate from the system at 10.0.8.8? Such a packet is useful for determining whether the firewall is allowing random packets in or out of your network.

- A. hping3 -T 10.0.8.8 -S netbios -c 2 -p 80
- B. hping3 -Y 10.0.8.8 -S windows -c 2 -p 80
- C. hping3 -O 10.0.8.8 -S server -c 2 -p 80
- D. hping3 -a 10.0.8.8 -S springfield -c 2 -p 80

Correct Answer: D

QUESTION 146

The GET method should never be used when sensitive data such as credit card is being sent to a CGI program. This is because any GET command will appear in the URL, and will be logged by any servers.

For example, let's say that you've entered your credit card information into a form that uses the GET method. The URL may appear like this:

<https://www.xsecurity-bank.com/creditcard.asp?cardnumber=453453433532234>

The GET method appends the credit card number to the URL. This means that anyone with access to a server log will be able to obtain this information. How would you protect from this type of attack?

- A. Never include sensitive information in a script
- B. Use HTTPS SSLv3 to send the data instead of plain HTTPS
- C. Replace the GET with POST method when sending data
- D. Encrypt the data before you send using GET method

Correct Answer: C

QUESTION 147

Lauren is performing a network audit for her entire company. The entire network is comprised of around 500 computers. Lauren starts an ICMP ping sweep by sending one IP packet to the broadcast address of the network, but only receives responses from around five hosts. Why did this ping sweep only produce a few responses?

- A. Only Windows systems will reply to this scan.
- B. A switched network will not respond to packets sent to the broadcast address.
- C. Only Linux and Unix-like (Non-Windows) systems will reply to this scan.
- D. Only servers will reply to this scan.

Correct Answer: C

QUESTION 148

Wayne is the senior security analyst for his company. Wayne is examining some traffic logs on a server and came across some inconsistencies. Wayne finds some IP packets from a computer purporting to be on the internal network. The packets originate from 192.168.12.35 with a TTL of 15. The server replied to this computer and received a response from 192.168.12.35 with a TTL of 21. What can Wayne infer from this traffic log?

- A. The initial traffic from 192.168.12.35 was being spoofed.
- B. The traffic from 192.168.12.25 is from a Linux computer.
- C. The TTL of 21 means that the client computer is on wireless.
- D. The client computer at 192.168.12.35 is a zombie computer.

Correct Answer: A

QUESTION 149

How do you defend against ARP Poisoning attack? (Select 2 answers)

- A. Enable DHCP Snooping Binding Table
- B. Restrict ARP Duplicates
- C. Enable Dynamic ARP Inspection
- D. Enable MAC snooping Table

Correct Answer: AC

QUESTION 150

You are the security administrator for a large network. You want to prevent attackers from running any sort of traceroute into your DMZ and discovering the internal structure of publicly accessible areas of the network. How can you achieve this?

- A. There is no way to completely block tracerouting into this area
- B. Block UDP at the firewall
- C. Block TCP at the firewall

D. Block ICMP at the firewall

Correct Answer: A

QUESTION 151

Neil is an IT security consultant working on contract for Davidson Avionics. Neil has been hired to audit the network of Davidson Avionics. He has been given permission to perform any tests necessary. Neil has created a fake company ID badge and uniform. Neil waits by one of the company's entrance doors and follows an employee into the office after they use their valid access card to gain entrance. What type of social engineering attack has Neil employed here?

- A. Neil has used a tailgating social engineering attack to gain access to the offices
- B. He has used a piggybacking technique to gain unauthorized access
- C. This type of social engineering attack is called man trapping
- D. Neil is using the technique of reverse social engineering to gain access to the offices of Davidson Avionics

Correct Answer: A

QUESTION 152

After a client sends a connection request (SYN) packet to the server, the server will respond (SYN-ACK) with a sequence number of its choosing, which then must be acknowledged (ACK) by the client. This sequence number is predictable; the attack connects to a service first with its own IP address, records the sequence number chosen, and then opens a second connection from a forged IP address. The attack doesn't see the SYN-ACK (or any other packet) from the server, but can guess the correct responses. If the source IP address is used for authentication, then the attacker can use the one-sided communication to break into the server.

What attacks can you successfully launch against a server using the above technique?

- A. Denial of Service attacks
- B. Session Hijacking attacks
- C. Web page defacement attacks
- D. IP spoofing attacks

Correct Answer: B

QUESTION 153

You are performing a port scan with nmap. You are in hurry and conducting the scans at the fastest possible speed. However, you don't want to sacrifice reliability for speed. If stealth is not an issue, what type of scan should you run to get very reliable results?

- A. Stealth scan
- B. Connect scan
- C. Fragmented packet scan
- D. XMAS scan

Correct Answer: B

QUESTION 154

You want to perform advanced SQL Injection attack against a vulnerable website. You are unable to perform command shell hacks on this server. What must be enabled in SQL Server to launch these attacks?

- A. System services
- B. EXEC master access

- C. xp_cmdshell
- D. RDC

Correct Answer: C

QUESTION 155

A majority of attacks come from insiders, people who have direct access to a company's computer system as part of their job function or a business relationship. Who is considered an insider?

- A. A competitor to the company because they can directly benefit from the publicity generated by making such an attack
- B. Disgruntled employee, customers, suppliers, vendors, business partners, contractors, temps, and consultants
- C. The CEO of the company because he has access to all of the computer systems
- D. A government agency since they know the company's computer system strengths and weaknesses

Correct Answer: B

QUESTION 156

An attacker is attempting to telnet into a corporation's system in the DMZ. The attacker doesn't want to get caught and is spoofing his IP address. After numerous tries he remains unsuccessful in connecting to the system. The attacker rechecks that the target system is actually listening on Port 23 and he verifies it with both nmap and hping2. He is still unable to connect to the target system. What could be the reason?

- A. The firewall is blocking port 23 to that system
- B. He needs to use an automated tool to telnet in
- C. He cannot spoof his IP and successfully use TCP
- D. He is attacking an operating system that does not reply to telnet even when open

Correct Answer: C

QUESTION 157

If an attacker's computer sends an IPID of 31 400 to a zombie (Idle Scanning) computer on an open port, what will be the response?

- A. 31 400
- B. 31 402
- C. The zombie will not send a response
- D. 31 401

Correct Answer: B

QUESTION 158

SSL has been seen as the solution to a lot of common security problems. Administrator will often time make use of SSL to encrypt communications from points A to point B. Why do you think this could be a bad idea if there is an Intrusion Detection System deployed to monitor the traffic between point A and B?

- A. SSL is redundant if you already have IDS's in place
- B. SSL will trigger rules at regular interval and force the administrator to turn them off
- C. SSL will slow down the IDS while it is breaking the encryption to see the packet content
- D. SSL will blind the content of the packet and Intrusion Detection Systems will not be able to detect them

Correct Answer: D

QUESTION 159

Jake is a network administrator who needs to get reports from all the computer and network devices on his network. Jake wants to use SNMP but is afraid that won't be secure since passwords and messages are in clear text. How can Jake gather network information in a secure manner?

- A. He can use SNMPv3
- B. Jake can use SNMPv5
- C. He can use SecWMI
- D. Jake can use SecSNMP

Correct Answer: A

QUESTION 160

Simon is security analyst writing signatures for a Snort node he placed internally that captures all mirrored traffic from his border firewall. From the following signature, what will Snort look for in the payload of the suspected packets?

alert tcp \$EXTERNAL_NET any -> \$HOME_NET 27374 (msg: "BACKDOOR SIG - SubSeven 22"; flags: A+; content: "|0d0a5b52504c5d3030320d0a|"; reference:arachnids, 485;)

- A. The payload of 485 is what this Snort signature will look for.
- B. Snort will look for 0d0a5b52504c5d3030320d0a in the payload.
- C. Packets that contain the payload of BACKDOOR SIG - SubSeven 22 will be flagged.
- D. From this snort signature, packets with HOME_NET 27374 in the payload will be flagged.

Correct Answer: B

QUESTION 161

You are trying to package a RAT Trojan so that Anti-Virus software will not detect it. Which of the listed technique will NOT be effective in evading Anti-Virus scanner?

- A. Convert the Trojan.exe file extension to Trojan.txt disguising as text file
- B. Break the Trojan into multiple smaller files and zip the individual pieces
- C. Change the content of the Trojan using hex editor and modify the checksum
- D. Encrypt the Trojan using multiple hashing algorithms like MD5 and SHA-1

Correct Answer: A

QUESTION 162

Oregon Corp is fighting a litigation suit with Scamster Inc. Oregon has assigned a private investigative agency to go through garbage, recycled paper, and other rubbish at Scamster's office site in order to find relevant information. What would you call this kind of activity?

- A. CI Gathering
- B. Scanning
- C. Dumpster Diving
- D. Garbage Scooping

Correct Answer: C

QUESTION 163

What type of port scan is represented here.



- A. Stealth Scan

- B. Full Scan
- C. XMAS Scan
- D. FIN Scan

Correct Answer: A

QUESTION 164

One way to defeat a multi-level security solution is to leak data via

- A. a bypass regulator.
- B. steganography.
- C. a covert channel.
- D. asymmetric routing.

Correct Answer: C

QUESTION 165

Least privilege is a security concept that requires that a user is

- A. limited to those functions required to do the job.
- B. given root or administrative privileges.
- C. trusted to keep all data and access to that data under their sole control.
- D. given privileges equal to everyone else in the department.

Correct Answer: A

QUESTION 166

A covert channel is a channel that

- A. transfers information over, within a computer system, or network that is outside of the security policy.
- B. transfers information over, within a computer system, or network that is within the security policy.
- C. transfers information via a communication path within a computer system, or network for transfer of data.
- D. transfers information over, within a computer system, or network that is encrypted.

Correct Answer: A

QUESTION 167

SOAP services use which technology to format information?

- A. SATA
- B. PCI
- C. XML
- D. ISDN

Correct Answer: C

QUESTION 168

Which of the following is a hashing algorithm?

- A. MD5
- B. PGP
- C. DES
- D. ROT13

Correct Answer: A

QUESTION 169

Which of the following identifies the three modes in which Snort can be configured to run?

- A. Sniffer, Packet Logger, and Network Intrusion Detection System

- B. Sniffer, Network Intrusion Detection System, and Host Intrusion Detection System
- C. Sniffer, Host Intrusion Prevention System, and Network Intrusion Prevention System
- D. Sniffer, Packet Logger, and Host Intrusion Prevention System

Correct Answer: A

QUESTION 170

Which of the following is a common Service Oriented Architecture (SOA) vulnerability?

- A. Cross-site scripting
- B. SQL injection
- C. VPath injection
- D. XML denial of service issues

Correct Answer: D

QUESTION 171

A company has five different subnets: 192. 68.1.0, 192.168.2.0,192.168.3.0,192.168.4.0 and 192.168.5.0. How can NMAP be used to scan these adjacent Class C networks?

- A. NMAP -P 192.168.1-5.
- B. NMAP -P 192.168.0.0/16
- C. NMAP -P 192.168.1.0,2.0,3.0,4.0,5.0
- D. NMAP -P 192.168.1/17

Correct Answer: A

QUESTION 172

When utilizing technical assessment methods to assess the security posture of a network, which of the following techniques would be most effective in determining whether end-user security training would be beneficial?

- A. Vulnerability scanning
- B. Social engineering
- C. Application security testing
- D. Network sniffing

Correct Answer: B

QUESTION 173

What is the broadcast address for the subnet 190.86.168.0/22?

- A. 190.86.168.255
- B. 190.86.255.255
- C. 190.86.171.255
- D. 190.86.169.255

Correct Answer: C

QUESTION 174

Which of the following are valid types of rootkits? (Choose three.)

- A. Hypervisor level
- B. Network level
- C. Kernel level
- D. Application level
- E. Physical level
- F. Data access level

Correct Answer: ACD

QUESTION 175

John the Ripper is a technical assessment tool used to test the weakness of which of the following?

- A. Usernames
- B. File permissions
- C. Firewall rulesets
- D. Passwords

Correct Answer: D

QUESTION 176

A company has made the decision to host their own email and basic web services. The administrator needs to set up the external firewall to limit what protocols should be allowed to get to the public part of the company's network. Which ports should the administrator open? (Choose three.)

- A. Port 22
- B. Port 23
- C. Port 25
- D. Port 53
- E. Port 80
- F. Port 139
- G. Port 445

Correct Answer: CDE

QUESTION 177

Which of the following items of a computer system will an anti-virus program scan for viruses?

- A. Boot Sector
- B. Deleted Files
- C. Windows Process List
- D. Password Protected Files

Correct Answer: A

QUESTION 178

Which of the following can take an arbitrary length of input and produce a message digest output of 160 bit?

- A. SHA-1
- B. MD5
- C. HAVAL
- D. MD4

Correct Answer: A

QUESTION 179

A hacker, who posed as a heating and air conditioning specialist, was able to install a sniffer program in a switched environment network. Which attack could the hacker use to sniff all of the packets in the network?

- A. Fraggle
- B. MAC Flood
- C. Smurf
- D. Tear Drop

Correct Answer: B

QUESTION 180

Which tool is used to automate SQL injections and exploit a database by forcing a given web application to connect to another database controlled by a hacker?

- A. DataThief
- B. NetCat
- C. Cain and Abel
- D. SQLInjector

Correct Answer: D

QUESTION 181

A security analyst is performing an audit on the network to determine if there are any deviations from the security policies in place. The analyst discovers that a user from the IT department had a dial-out modem installed. Which security policy must the security analyst check to see if dial-out modems are allowed?

- A. Firewall-management policy
- B. Acceptable-use policy
- C. Remote-access policy
- D. Permissive policy

Correct Answer: C

QUESTION 182

When an alert rule is matched in a network-based IDS like snort, the IDS does which of the following?

- A. Drops the packet and moves on to the next one
- B. Continues to evaluate the packet until all rules are checked
- C. Stops checking rules, sends an alert, and lets the packet continue
- D. Blocks the connection with the source IP address in the packet

QUESTION 183

Which of the following types of firewall inspects only header information in network traffic?

- A. Packet filter
- B. Stateful inspection
- C. Circuit-level gateway
- D. Application-level gateway

Correct Answer: A

QUESTION 184

What is the main disadvantage of the scripting languages as opposed to compiled programming languages?

- A. Scripting languages are hard to learn.
- B. Scripting languages are not object-oriented.
- C. Scripting languages cannot be used to create graphical user interfaces.
- D. Scripting languages are slower because they require an interpreter to run the code.

Correct Answer: D

QUESTION 185

Which of the following are password cracking tools? (Choose three.)

- A. BTCrack
- B. John the Ripper
- C. KerbCrack
- D. Nikto

E. Cain and Abel

F. Havij

Correct Answer: BCE

QUESTION 186

Which type of antenna is used in wireless communication?

A. Omnidirectional

B. Parabolic

C. Uni-directional

D. Bi-directional

Correct Answer: A

QUESTION 187

Employees in a company are no longer able to access Internet web sites on their computers. The network administrator is able to successfully ping IP address of web servers on the Internet and is able to open web sites by using an IP address in place of the URL. The administrator runs the nslookup command for www.eccouncil.org and receives an error message stating there is no response from the server. What should the administrator do next?

A. Configure the firewall to allow traffic on TCP ports 53 and UDP port 53.

B. Configure the firewall to allow traffic on TCP ports 80 and UDP port 443.

C. Configure the firewall to allow traffic on TCP port 53.

D. Configure the firewall to allow traffic on TCP port 8080.

Correct Answer: A

QUESTION 188

What is the most secure way to mitigate the theft of corporate information from a laptop that was left in a hotel room?

A. Set a BIOS password.

B. Encrypt the data on the hard drive.

C. Use a strong logon password to the operating system.

D. Back up everything on the laptop and store the backup in a safe place.

Correct Answer: B

QUESTION 189

Which of the following scanning tools is specifically designed to find potential exploits in Microsoft Windows products?

A. Microsoft Security Baseline Analyzer

B. Retina

C. Core Impact

D. Microsoft Baseline Security Analyzer

Correct Answer: D

QUESTION 190

Which of the statements concerning proxy firewalls is correct?

A. Proxy firewalls increase the speed and functionality of a network.

B. Firewall proxy servers decentralize all activity for an application.

C. Proxy firewalls block network packets from passing to and from a protected network.

D. Computers establish a connection with a proxy firewall which initiates a new network connection for

the client.

Correct Answer: D

QUESTION 191

Which of the following is an example of two factor authentication?

- A. PIN Number and Birth Date
- B. Username and Password
- C. Digital Certificate and Hardware Token
- D. Fingerprint and Smartcard ID

Correct Answer: D

QUESTION 192

What is the outcome of the command `nc -l -p 2222 | nc 1 0.1 .0.43 1 234`?

- A. Netcat will listen on the 1 0.1 .0.43 interface for 1 234 seconds on port 2222.
- B. Netcat will listen on port 2222 and output anything received to a remote connection on 1 0.1 .0.43 port 1 234.
- C. Netcat will listen for a connection from 1 0.1 .0.43 on port 1 234 and output anything received to port 2222.
- D. Netcat will listen on port 2222 and then output anything received to local interface 1 0.1 .0.43.

Correct Answer: B

QUESTION 193

For messages sent through an insecure channel, a properly implemented digital signature gives the receiver reason to believe the message was sent by the claimed sender. While using a digital signature, the message digest is encrypted with which key?

- A. Sender's public key
- B. Receiver's private key
- C. Receiver's public key
- D. Sender's private key

Correct Answer: D

QUESTION 194

When using Wireshark to acquire packet capture on a network, which device would enable the capture of all traffic on the wire?

- A. Network tap
- B. Layer 3 switch
- C. Network bridge
- D. Application firewall

Correct Answer: A

QUESTION 195

How does an operating system protect the passwords used for account logins?

- A. The operating system performs a one-way hash of the passwords.
- B. The operating system stores the passwords in a secret file that users cannot find.
- C. The operating system encrypts the passwords, and decrypts them when needed.
- D. The operating system stores all passwords in a protected segment of non-volatile memory.

Correct Answer: A

QUESTION 196

Which of the following programs is usually targeted at Microsoft Office products?

- A. Polymorphic virus
- B. Multipart virus
- C. Macro virus
- D. Stealth virus

Correct Answer: C

QUESTION 197

What is the main difference between a "Normal" SQL Injection and a "Blind" SQL Injection vulnerability?

- A. The request to the web server is not visible to the administrator of the vulnerable application.
- B. The attack is called "Blind" because, although the application properly filters user input, it is still vulnerable to code injection.
- C. The successful attack does not show an error message to the administrator of the affected application.
- D. The vulnerable application does not display errors with information about the injection results to the attacker.

Correct Answer: D

QUESTION 198

Smart cards use which protocol to transfer the certificate in a secure manner?

- A. Extensible Authentication Protocol (EAP)
- B. Point to Point Protocol (PPP)
- C. Point to Point Tunneling Protocol (PPTP)
- D. Layer 2 Tunneling Protocol (L2TP)

Correct Answer: A

QUESTION 199

Which of the following is a protocol that is prone to a man-in-the-middle (MITM) attack and maps a 32-bit address to a 48-bit address?

- A. ICPM
- B. ARP
- C. RARP
- D. ICMP

Correct Answer: B

QUESTION 200

Which NMAP feature can a tester implement or adjust while scanning for open ports to avoid detection by the network's IDS?

- A. Timing options to slow the speed that the port scan is conducted
- B. Fingerprinting to identify which operating systems are running on the network
- C. ICMP ping sweep to determine which hosts on the network are not available
- D. Traceroute to control the path of the packets sent during the scan

Correct Answer: A

QUESTION 201

Windows file servers commonly hold sensitive files, databases, passwords and more. Which of the following choices would be a common vulnerability that usually exposes them?

- A. Cross-site scripting

- B. SQL injection
- C. Missing patches
- D. CRLF injection

Correct Answer: C

QUESTION 202

Which type of access control is used on a router or firewall to limit network activity?

- A. Mandatory
- B. Discretionary
- C. Rule-based
- D. Role-based

Correct Answer: C

QUESTION 203

Which types of detection methods are employed by Network Intrusion Detection Systems (NIDS)?
(Choose two.)

- A. Signature
- B. Anomaly
- C. Passive
- D. Reactive

Correct Answer: AB